Vendor Security Assessment Guide

Document owner: Third-Party Risk

Review frequency: Annual

Classification: Internal

Purpose

This guide explains how procurement and Security assess a vendor before sensitive information or production connectivity is approved.

Scope and definitions

A vendor is an external service provider processing company or customer information. A critical vendor can affect confidentiality, integrity, availability, or a regulated business process. A security questionnaire is evidence to review, not a substitute for verification.

Roles

The business sponsor documents purpose, data, integrations, and business dependency. Procurement confirms contractual terms and subprocessors. Security reviews access controls, encryption, incident handling, vulnerability management, and independent assurance. Privacy reviews personal-data flows. Legal approves contract language.

Assessment procedure

1. Classify proposed data and identify tenant or customer boundaries.

2. Request current assurance artifacts, incident-notification terms, data location, retention/deletion commitments, and a subprocessor list.

3. Scope requested API credentials to the minimum resources; require individual administrative identities and multifactor authentication where supported.

4. Verify encryption, backup, change management, access review, and tested recovery evidence against the proposed service tier.

5. Record gaps, compensating controls, accountable owners, approval, and reassessment date before production data is shared.

Rules and exceptions

No vendor receives credentials or Restricted data before written approval. A time-limited pilot uses synthetic or minimized data unless an exception is approved. Exceptions require Security, Privacy, and business-owner approval and an expiry.

Audit and review

Retain the assessment, decision, contract, and remediation evidence in the controlled vendor record. Reassess critical vendors annually and after a material incident or service change.